

Here are 15 multiple-choice questions for each of the 5 lecture notes, ordered from least difficult to most difficult, complete with answers and explanations derived directly from the source materials.

Lecture 1: Introduction to Information Systems Security

Question 1 (Easy)

What is considered the most important—and often the weakest—component of an Information System?

- A. Software
- B. Hardware
- C. People
- D. Networks

Answer: C. People

Explanation: Humans/People are defined as the most important component and are often considered the weakest link due to social engineering, poor password practices, and accidental mistakes.

Question 2 (Easy)

What does the acronym "CIA" stand for in the foundational CIA Triad of information security?

- A. Control, Integrity, Access
- B. Confidentiality, Integrity, Availability
- C. Cyber, Information, Assets
- D. Confidentiality, Inspection, Authenticity

Answer: B. Confidentiality, Integrity, Availability

Explanation: The CIA Triad consists of Confidentiality, Integrity, and Availability.

Question 3 (Easy)

Which core security principle ensures that information is accurate, complete, and unaltered?

- A. Confidentiality
- B. Availability
- C. Non-repudiation
- D. Integrity

Answer: D. Integrity

Explanation: Integrity ensures that information is accurate, complete, and unaltered.

Question 4 (Easy)

A Multi-Factor Authentication (MFA) system is an example of which type of security control?

- A. Preventive Control
- B. Detective Control

- C. Corrective Control
- D. Compensating Control

Answer: A. Preventive Control

Explanation: Preventive controls include Firewalls, Encryption, MFA, and Security awareness training.

Question 5 (Easy)

Which of the following is an example of an environmental threat to an information system?

- A. Hackers
- B. Cyclones
- C. Power outages
- D. Malware

Answer: C. Power outages

Explanation: Environmental threats listed include Fire, Power outages, and Water leaks.

Question 6 (Medium)

An attacker modifies a student's mark in a database from 62 to 92. Which principle of the CIA Triad has been directly violated?

- A. Confidentiality
- B. Availability
- C. Integrity
- D. Authenticity

Answer: C. Integrity

Explanation: Unauthorised alteration of data (such as changing a grade) is a direct compromise of Integrity.

Question 7 (Medium)

Which category of security controls includes Intrusion Detection Systems (IDS), CCTV, and security logs?

- A. Corrective Controls
- B. Detective Controls
- C. Preventive Controls
- D. Administrative Controls

Answer: B. Detective Controls

Explanation: Detective controls include IDS, Security logs, SIEM solutions, and CCTV.

Question 8 (Medium)

Which security mechanism is specifically classified as a corrective control?

- A. Encryption
- B. Firewalls
- C. Backups
- D. Security awareness training

Answer: C. Backups

Explanation: Corrective controls include Backups, Disaster Recovery Plans, Patch management, and Incident response.

Question 9 (Medium)

During the 2017 WannaCry attack, how did the ransomware primarily spread globally?

- A. Through social engineering phishing emails
- B. By exploiting a vulnerability in Microsoft Windows systems
- C. Through physical USB drives infected with keyloggers
- D. By brute-forcing default administrator passwords on routers

Answer: B. By exploiting a vulnerability in Microsoft Windows systems

Explanation: The WannaCry ransomware spread globally within hours by exploiting a vulnerability in Microsoft Windows systems.

Question 10 (Medium)

Which of the following defines a **vulnerability**?

- A. Any event that has the potential to cause harm
- B. Anything of value that requires protection
- C. A weakness that can be exploited
- D. The likelihood that harm will occur

Answer: C. A weakness that can be exploited

Explanation: A vulnerability is defined as a weakness that can be exploited.

Question 11 (Hard)

What is the qualitative formula used to determine **Risk** in information systems security?

- A. $\text{Risk} = \text{Asset} \times \text{Threat} \times \text{Control}$
- B. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
- C. $\text{Risk} = \text{Vulnerability} + \text{Threat} - \text{Control}$
- D. $\text{Risk} = \frac{\text{Impact} \times \text{Vulnerability}}{\text{Threat}}$

Answer: B. $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

Explanation: The lecture notes state the qualitative relationship as $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$.

Question 12 (Hard)

Students are unable to access a university's online registration portal because the servers are flooded by a Distributed Denial-of-Service (DDoS) attack. Which security principle is compromised, and which control could best help mitigate this threat?

- A. Integrity; Hash functions

- B. Confidentiality; Encryption
- C. Availability; Load Balancing
- D. Authenticity; Digital Signatures

Answer: C. Availability; Load Balancing

Explanation: A DDoS attack compromises Availability, and Load Balancing is listed as a control to preserve availability.

Question 13 (Hard)

Which of the following is NOT listed as a lesson learned from the WannaCry ransomware case study?

- A. Segment networks to limit lateral movement
- B. Apply security patches promptly
- C. Maintain offline and tested backups
- D. Replace all Windows operating systems with Linux open-source alternatives

Answer: D. Replace all Windows operating systems with Linux open-source alternatives

Explanation: The lessons learned from WannaCry were: applying patches, maintaining offline backups, segmenting networks, training users, and testing incident response plans.

Question 14 (Hard)

Information Security is defined as preserving Confidentiality, Integrity, and Availability while ensuring four additional properties. Which of the following is **NOT** one of those four additional properties?

- A. Authenticity
- B. Accountability
- C. Non-repudiation
- D. Scalability

Answer: D. Scalability

Explanation: Information Security preserves CIA while ensuring Authenticity, Accountability, Non-repudiation, and Reliability.

Question 15 (Hardest)

An exposed web server hosting critical student records faces frequent internet attacks. If an administrator implements patch management and deploys an Intrusion Detection System (IDS), which risk components and security control types are being addressed respectively?

- A. Reducing Vulnerability using a Corrective Control; adding a Detective Control
- B. Reducing Threat using a Preventive Control; adding a Corrective Control
- C. Reducing Impact using a Detective Control; adding a Preventive Control
- D. Eliminating Risk using an Administrative Control; adding a Physical Control

Answer: A. Reducing Vulnerability using a Corrective Control; adding a Detective Control

Explanation: Patching addresses vulnerabilities and is categorized as a Corrective Control. An IDS acts as a Detective Control.

Lecture 2: Information Systems Security Vulnerabilities

Question 1 (Easy)

What is a security vulnerability?

- A. An active attacker attempting to steal data
- B. A weakness or flaw in design, implementation, configuration, or operation
- C. The financial impact of a data breach
- D. A software script used to perform an attack

Answer: B. A weakness or flaw in design, implementation, configuration, or operation

Explanation: A security vulnerability is defined as a weakness or flaw in design, implementation, configuration, or operation that can be exploited.

Question 2 (Easy)

In social engineering, what is **phishing**?

- A. Scanning network ports for open vulnerabilities
- B. Overwriting memory registers using malicious inputs
- C. Sending fake emails designed to trick users into revealing sensitive information
- D. Intercepting unencrypted web traffic over HTTP

Answer: C. Sending fake emails designed to trick users into revealing sensitive information

Explanation: Phishing consists of fake emails designed to steal information.

Question 3 (Easy)

Which insecure network protocol transmits data in cleartext and exposes credentials to network eavesdroppers compared to its secure counterpart?

- A. HTTPS
- B. HTTP
- C. SSH
- D. SFTP

Answer: B. HTTP

Explanation: Using HTTP instead of HTTPS exposes usernames, passwords, and session cookies to attackers on the same network.

Question 4 (Easy)

Which software tool/platform allows organizations to centrally monitor, manage, secure, and enforce security policies on mobile devices?

- A. SIEM
- B. MDM (Mobile Device Management)
- C. EDR

- D. IDS

Answer: B. MDM (Mobile Device Management)

Explanation: MDM is security software that lets organizations secure, monitor, manage, and push policies to mobile devices from a central platform.

Question 5 (Easy)

What security practice involves blocking unauthorized software, scripts, and code from running on a host?

- A. Device Encryption
- B. Application Control
- C. Remote Wipe
- D. Biometric Authentication

Answer: B. Application Control

Explanation: Application control is a practice that blocks unauthorized software, scripts, and code from running on a system.

Question 6 (Medium)

What type of flaw occurs when a program receives more input than its allocated memory space can hold, potentially leading to remote code execution?

- A. SQL Injection
- B. Cross-Site Scripting
- C. Buffer Overflow
- D. Security Misconfiguration

Answer: C. Buffer Overflow

Explanation: A buffer overflow occurs when a program writes more data into memory than allocated.

Question 7 (Medium)

Which defensive coding technique is recommended to prevent **SQL Injection** vulnerabilities?

- A. Using HTTP instead of HTTPS
- B. Parameterized queries / Prepared statements
- C. Implementing Remote Wipe
- D. Disabling host-based firewalls

Answer: B. Parameterized queries / Prepared statements

Explanation: Parameterized queries, prepared statements, and input validation are listed as key mitigations against SQL Injection.

Question 8 (Medium)

According to the OWASP Top 10 (2025), what vulnerability ranks as **A01:2025**?

- A. Security Misconfiguration
- B. Broken Access Control
- C. Cryptographic Failures

- D. Injection

Answer: B. Broken Access Control

Explanation: A01:2025 in the OWASP Top 10 is Broken Access Control.

Question 9 (Medium)

In the context of physical/hardware vulnerability mitigation, what security command deletes all data and resets a lost or stolen mobile device over the internet?

- A. Application Control
- B. Remote Wipe
- C. Hard Reset
- D. Firmware Flashing

Answer: B. Remote Wipe

Explanation: A remote wipe is a security command sent over the internet to delete all data and reset a lost or stolen device.

Question 10 (Medium)

What is targeted social engineering specifically directed against a particular individual or organization called?

- A. Phishing
- B. Spear Phishing
- C. Buffer Overflowing
- D. Pretexting

Answer: B. Spear Phishing

Explanation: Spear phishing is defined as targeted phishing against specific individuals.

Question 11 (Hard)

In the vulnerability chain diagram provided in Lecture 2, what is the correct flow sequence from threat to damage?

- A. Threat $\rightarrow$ Vulnerability $\rightarrow$ Exploits $\rightarrow$ Asset $\rightarrow$ Damage
- B. Threat $\rightarrow$ Exploits $\rightarrow$ Vulnerability $\rightarrow$ Asset $\rightarrow$ Damage
- C. Asset $\rightarrow$ Vulnerability $\rightarrow$ Threat $\rightarrow$ Exploits $\rightarrow$ Damage
- D. Vulnerability $\rightarrow$ Threat $\rightarrow$ Asset $\rightarrow$ Exploits $\rightarrow$ Damage

Answer: B. Threat $\rightarrow$ Exploits $\rightarrow$ Vulnerability $\rightarrow$ Asset $\rightarrow$ Damage

Explanation: The diagram shows: Threat (Cybercriminal) $\rightarrow$ Exploits (Password guessing) $\rightarrow$ Vulnerability (Weak admin password) $\rightarrow$ Asset (Database) $\rightarrow$ Damage (Data stolen).

Question 12 (Hard)

An attacker inputs ' OR '1'=1 into a login form's username field. What vulnerability is the attacker attempting to exploit, and what is the outcome?

- A. Buffer Overflow; System crash
- B. SQL Injection; Authentication bypass
- C. Broken Access Control; Privilege escalation
- D. Cryptographic Failure; Plaintext password extraction

Answer: B. SQL Injection; Authentication bypass

Explanation: Entering ' OR '1'=1 manipulates the database query logic to evaluate as true, resulting in an authentication bypass.

Question 13 (Hard)

Which OWASP Top 10 (2025) risk category covers vulnerabilities related to **Software Supply Chain Failures**?

- A. A02:2025
- B. A03:2025
- C. A05:2025
- D. A08:2025

Answer: B. A03:2025

Explanation: According to the provided list, A03:2025 represents "Software Supply Chain Failures".

Question 14 (Hard)

Why are hardware/firmware vulnerabilities considered uniquely dangerous compared to software vulnerabilities?

- A. They only occur in open-source operating systems
- B. Compromised firmware is difficult to detect and remove, and affects physical operational layers directly
- C. Hardware vulnerabilities can be automatically patched via standard web browsers
- D. They only affect mobile devices using Wi-Fi networks

Answer: B. Compromised firmware is difficult to detect and remove, and affects physical operational layers directly

Explanation: Lecture 2 highlights that firmware controls hardware operation and compromised firmware is difficult to detect and remove.

Question 15 (Hardest)

If an organization connects all user devices, web servers, and database servers onto a single flat network without subnets or VLANs, which network vulnerability is present and what is its primary risk?

- A. Open Ports; allows external hackers to bypass firewalls
- B. Poor Network Segmentation; allows malware to spread rapidly across systems if one device is compromised

- C. Insecure Protocols; exposes passwords in cleartext
- D. Firmware Flaws; leads to permanent hardware failure

Answer: B. Poor Network Segmentation; allows malware to spread rapidly across systems if one device is compromised

Explanation: Poor network segmentation (flat networks) allows lateral movement so malware can spread rapidly to other systems if one device is compromised.

Lecture 3: Threat Modelling and Scoping an Information System

Question 1 (Easy)

What organization produces the widely used threat modelling guidelines and OWASP Top 10?

- A. Open Worldwide Application Security Project
- B. Organization of Web Application Safety Protocols
- C. Online World Architecture Security Panel
- D. Official Web Application System Program

Answer: A. Open Worldwide Application Security Project

Explanation: OWASP stands for the Open Worldwide Application Security Project.

Question 2 (Easy)

What mnemonic is widely used to identify cyber threats in threat modelling?

- A. OWASP
- B. CIA
- C. STRIDE
- D. SDLC

Answer: C. STRIDE

Explanation: STRIDE is a threat mnemonic useful in identifying threats.

Question 3 (Easy)

In STRIDE, what does the letter **S** stand for?

- A. System Flaw
- B. Spoofing
- C. Software Bug
- D. Sniffing

Answer: B. Spoofing

Explanation: S in STRIDE stands for Spoofing identity.

Question 4 (Easy)

What defines an **Entry Point** in a system threat model?

- A. The database where log files are stored permanently

- B. Interfaces through which an attacker or user can interact with the application or supply data
- C. The exact network cable connecting a router to an ISP
- D. The physical building entrance for employees

Answer: B. Interfaces through which an attacker or user can interact with the application or supply data

Explanation: Entry points are interfaces through which potential attackers or users can interact with an application or supply it with data.

Question 5 (Easy)

Which question represents Step 1 / Question 1 of the four core OWASP threat modelling questions?

- A. What can go wrong?
- B. What are we working on?
- C. What are we going to do about it?
- D. Did we do a good enough job?

Answer: B. What are we working on?

Explanation: Question 1 of the four OWASP questions is "What are we working on?" (Scope Your Work).

Question 6 (Medium)

In STRIDE, modifying unauthorized data corresponds to **Tampering**. Which mitigation technique directly counters Tampering?

- A. Appropriate Authentication
- B. Hashes, MACs, and Digital Signatures
- C. Throttling and Quality of Service
- D. Privacy-enhanced protocols

Answer: B. Hashes, MACs, and Digital Signatures

Explanation: Mitigations listed for Tampering with data include appropriate authorization, hashes, MACs, digital signatures, and tamper-resistant protocols.

Question 7 (Medium)

An attacker pretends to be a legitimate student to log into a portal. Which STRIDE category does this threat belong to?

- A. Repudiation
- B. Spoofing
- C. Information Disclosure
- D. Elevation of Privilege

Answer: B. Spoofing

Explanation: Spoofing is defined as "Pretending to be another user".

Question 8 (Medium)

Which STRIDE threat describes a situation where an attacker gains administrative/higher privileges than authorized?

- A. Elevation of Privilege
- B. Tampering
- C. Repudiation
- D. Denial of Service

Answer: A. Elevation of Privilege

Explanation: Elevation of Privilege involves obtaining unauthorized privileges.

Question 9 (Medium)

What is the primary purpose of defining a **Trust Level** in threat modelling?

- A. To specify the internet connection speed of end users
- B. To represent the degree of access or privilege granted to an entity
- C. To measure the physical distance between servers
- D. To determine the hardware cost of client workstations

Answer: B. To represent the degree of access or privilege granted to an entity

Explanation: A trust level represents the degree of access or privilege granted to an entity.

Question 10 (Medium)

What threat modelling activity should be conducted during the **Requirements** stage of the Software Development Life Cycle (SDLC)?

- A. Identify security requirements and important assets
- B. Develop security test cases
- C. Review infrastructure and external dependencies
- D. Identify components, data flows, and trust boundaries

Answer: A. Identify security requirements and important assets

Explanation: In the SDLC table, the Requirements stage activity is "Identify security requirements and important assets".

Question 11 (Hard)

In STRIDE, **Repudiation** refers to a user denying an action they performed. Which mitigations are specifically recommended to combat Repudiation?

- A. Encryption and Privacy-enhanced protocols
- B. Digital signatures, Timestamps, and Audit trails
- C. Throttling and Filtering
- D. Running with least privilege

Answer: B. Digital signatures, Timestamps, and Audit trails

Explanation: The mitigations listed for Repudiation are Digital signatures, Timestamps, and Audit trails.

Question 12 (Hard)

What is the difference between a **Normal Use Case** and a **Misuse Case** in threat modelling?

- A. Normal use cases describe system deployment; misuse cases describe software updates
- B. Normal use cases describe intended user interactions (e.g., Student logs in); misuse cases describe malicious attacker actions (e.g., Attacker steals credentials)
- C. Normal use cases apply to administrators; misuse cases apply to guest users
- D. Normal use cases are written in code; misuse cases are written in plain text

Answer: B. Normal use cases describe intended user interactions (e.g., Student logs in); misuse cases describe malicious attacker actions (e.g., Attacker steals credentials)

Explanation: The comparison table highlights that Normal Use Cases reflect valid actions (e.g., Student registers course) while Misuse Cases reflect attack scenarios (e.g., Attacker registers on behalf of student).

Question 13 (Hard)

When mapping STRIDE threats to security properties, **Information Disclosure** directly violates which CIA Triad property, and what is its primary mitigation?

- A. Availability; Throttling
- B. Integrity; Digital Signatures
- C. Confidentiality; Encryption / Privacy-enhanced protocols
- D. Authenticity; Passwords

Answer: C. Confidentiality; Encryption / Privacy-enhanced protocols

Explanation: Information Disclosure exposes confidential data (violating Confidentiality); its mitigations include authorization, privacy-enhanced protocols, and encryption.

Question 14 (Hard)

Why is integrating threat modelling early in the SDLC (e.g., Design/Architecture) financially and operationally beneficial?

- A. It completely removes the need for penetration testing
- B. Fixing design flaws early is significantly easier and cheaper than fixing them after deployment
- C. It automates code writing so fewer developers are needed
- D. It guarantees 100% immune systems against all future malware

Answer: B. Fixing design flaws early is significantly easier and cheaper than fixing them after deployment

Explanation: The lecture notes state that discovering design weaknesses early makes them easier and cheaper to address.

Question 15 (Hardest)

In a university system, a Web Application receives input from an Anonymous Web User (\$T0\$), processes it, and queries a Database containing Student Records. Where does a **Trust Boundary** change occur, and what security threat must be evaluated when crossing from \$T0\$ to higher trust levels?

- A. At the hardware network switch; Physical Tampering

- B. At entry points where data moves across entities with different privileges; Spoofing / Injection
- C. Inside the database storage engine only; Repudiation
- D. At the client web browser; Denial of Service

Answer: B. At entry points where data moves across entities with different privileges; Spoofing / Injection

Explanation: Entry and exit points define trust boundaries where user trust levels change, requiring validation and authentication controls.

Lecture 4: Identification, Authentication and Access Control

Question 1 (Easy)

Claiming who you are (e.g., entering a username) represents which concept?

- A. Authentication
- B. Identification
- C. Authorization
- D. Accountability

Answer: B. Identification

Explanation: Identification is the process by which a user or entity claims an identity (e.g., Username).

Question 2 (Easy)

Proving your claimed identity (e.g., providing a matching password or OTP) is called:

- A. Identification
- B. Authentication
- C. Authorization
- D. Accounting

Answer: B. Authentication

Explanation: Authentication is the process of verifying that a claimant is actually associated with the identity being claimed.

Question 3 (Easy)

Determining what permissions or resources an authenticated user is permitted to access is known as:

- A. Authorization
- B. Authentication
- C. Identification
- D. Non-repudiation

Answer: A. Authorization

Explanation: Authorization determines what an authenticated user is allowed to access.

Question 4 (Easy)

A password or PIN falls under which authentication factor category?

- A. Something you have
- B. Something you know
- C. Something you are
- D. Somewhere you are

Answer: B. Something you know

Explanation: "Something you know" includes Passwords, PINs, and Passphrases.

Question 5 (Easy)

Fingerprint and facial recognition scans belong to which authentication factor category?

- A. Something you know
- B. Something you have
- C. Something you are
- D. Something you do

Answer: C. Something you are

Explanation: "Something you are" refers to biometric authentication (e.g., fingerprint, face).

Question 6 (Medium)

Combining a Password with a PIN constitutes Multi-Factor Authentication (MFA). True or False?

- A. True, because it uses two secret credentials
- B. False, because both belong to the same factor category ("Something you know")
- C. True, provided they are entered on different screens
- D. False, because PINs cannot be encrypted

Answer: B. False, because both belong to the same factor category ("Something you know")

Explanation: Password + PIN is NOT MFA because both are in the "Something You Know" category. MFA requires independent factor categories.

Question 7 (Medium)

What unique value is added to a password before hashing to ensure that identical passwords do not produce identical stored hashes?

- A. Encryption Key
- B. Salt
- C. Digital Certificate
- D. Session ID

Answer: B. Salt

Explanation: A password salt is a unique random value added before hashing to prevent identical passwords from producing identical hashes.

Question 8 (Medium)

Which password attack involves attempting a single common password across a large number of different user accounts?

- A. Brute Force Attack
- B. Credential Stuffing
- C. Password Spraying
- D. Dictionary Attack

Answer: C. Password Spraying

Explanation: Password spraying is defined as trying one common password against many accounts.

Question 9 (Medium)

Which access control model assigns permissions to roles, and then assigns users to those roles?

- A. Discretionary Access Control (DAC)
- B. Mandatory Access Control (MAC)
- C. Role-Based Access Control (RBAC)
- D. Attribute-Based Access Control (ABAC)

Answer: C. Role-Based Access Control (RBAC)

Explanation: RBAC assigns permissions to roles, and users are assigned to roles.

Question 10 (Medium)

Which core security principle states that users should receive only the minimum permissions necessary to perform their legitimate job duties?

- A. Principle of Least Privilege
- B. Separation of Duties
- C. Defense in Depth
- D. Mandatory Access Control

Answer: A. Principle of Least Privilege

Explanation: The Principle of Least Privilege ensures users receive only permissions necessary to perform their legitimate duties.

Question 11 (Hard)

Why does OWASP specifically recommend memory-intensive/slow algorithms like **Argon2id** over general-purpose cryptographic hashes like **SHA-256** for password storage?

- A. SHA-256 is reversible, whereas Argon2id is unencrypted
- B. SHA-256 is designed to be fast, making high-speed offline brute-force and dictionary attacks easier for attackers
- C. Argon2id does not require salt values
- D. SHA-256 cannot be used over TLS connections

Answer: B. SHA-256 is designed to be fast, making high-speed offline brute-force and dictionary attacks easier for attackers

Explanation: Fast hashes like SHA-256 allow attackers to compute billions of guesses per second. Password hashing should deliberately be slow and computationally expensive (e.g., Argon2id).

Question 12 (Hard)

What is the primary architectural difference between **OAuth 2.0** and **OpenID Connect (OIDC)**?

- A. OAuth 2.0 is an authentication protocol, while OIDC is an access control model
- B. OAuth 2.0 is an authorization framework for delegated access; OpenID Connect is an authentication layer built on top of OAuth 2.0
- C. OAuth 2.0 uses biometrics, whereas OIDC uses passwords
- D. OAuth 2.0 is used for DAC networks, while OIDC is used for MAC networks

Answer: B. OAuth 2.0 is an authorization framework for delegated access; OpenID Connect is an authentication layer built on top of OAuth 2.0

Explanation: OAuth is primarily an authorization framework; OpenID Connect (OIDC) is used on top of OAuth 2.0 specifically for authentication.

Question 13 (Hard)

An access control system evaluates rules such as: IF User.Role = Lecturer AND Resource.Course = User.AssignedCourse AND Time = WorkingHours THEN Allow. Which access control model is being utilized?

- A. Discretionary Access Control (DAC)
- B. Mandatory Access Control (MAC)
- C. Role-Based Access Control (RBAC)
- D. Attribute-Based Access Control (ABAC)

Answer: D. Attribute-Based Access Control (ABAC)

Explanation: ABAC makes decisions based on multiple dynamic attributes including User, Resource, Environment, Time, Location, etc.

Question 14 (Hard)

What type of attack involves taking previously leaked username/password combinations from one compromised site and trying them against another unrelated service?

- A. Brute Force Attack
- B. Password Spraying
- C. Credential Stuffing
- D. Man-in-the-Middle Attack

Answer: C. Credential Stuffing

Explanation: Credential stuffing is defined as using previously leaked username/password combinations against another service.

Question 15 (Hardest)

In an organization using **Discretionary Access Control (DAC)** versus **Mandatory Access Control (MAC)**, who determines the access permissions on an asset, and what is the main

security risk associated with DAC?

- A. DAC permissions are set by the System Admin; MAC permissions are set by the User. Risk: High latency.
- B. DAC permissions are set by the Owner of the resource; MAC permissions are set by central security policies. Risk: In DAC, users may unintentionally grant excessive access to others.
- C. DAC uses biometrics; MAC uses passwords. Risk: Biometric spoofing.
- D. DAC is enforced by hardware; MAC is enforced by software. Risk: Hardware failure.

Answer: B. DAC permissions are set by the Owner of the resource; MAC permissions are set by central security policies. Risk: In DAC, users may unintentionally grant excessive access to others.

Explanation: In DAC, the resource owner controls access, but a key disadvantage is that users may unintentionally provide excessive access. MAC relies on central security policies.

Lecture 5: Network Information System

Question 1 (Easy)

Which area coverage classification applies to a computer network spanning across a single city or town?

- A. PAN
- B. LAN
- C. MAN
- D. WAN

Answer: C. MAN

Explanation: A Metropolitan Area Network (MAN) spans a city or town.

Question 2 (Easy)

Which network architecture contains no dedicated servers, where all connected nodes are equal and independent?

- A. Client-Server
- B. Peer-to-Peer (P2P)
- C. Switched Network
- D. Mainframe-Terminal

Answer: B. Peer-to-Peer (P2P)

Explanation: In Peer-to-Peer architecture, there are no dedicated servers and all computers are equal (peers).

Question 3 (Easy)

How many layers are present in the OSI Reference Model?

- A. 4
- B. 5
- C. 6

- D. 7

Answer: D. 7

Explanation: The OSI Model consists of 7 layers (Physical to Application).

Question 4 (Easy)

What is the lowest layer (Layer 1) of the OSI Reference Model?

- A. Data Link Layer
- B. Network Layer
- C. Physical Layer
- D. Transport Layer

Answer: C. Physical Layer

Explanation: Layer 1 of the OSI Model is the Physical Layer.

Question 5 (Easy)

In which network topology are all devices connected to a single central hub or switch?

- A. Bus Topology
- B. Star Topology
- C. Ring Topology
- D. Mesh Topology

Answer: B. Star Topology

Explanation: Star topology features processing nodes directly interconnecting with a central system/hub.

Question 6 (Medium)

In which network topology does a single central cable act as a backbone with two distinct endpoints, where a cable break stops the whole network from functioning?

- A. Star Topology
- B. Bus Topology
- C. Mesh Topology
- D. Ring Topology

Answer: B. Bus Topology

Explanation: In Bus topology, a single network cable (bus/backbone) runs through the network; a cable break can cause the whole network to stop functioning.

Question 7 (Medium)

What is the Protocol Data Unit (PDU) / unit of exchange created at the **Data Link Layer** (Layer 2) of the OSI Model?

- A. Bit
- B. Frame
- C. Packet
- D. Segment

Answer: B. Frame

Explanation: The Data Link layer packs bytes/packets into **Frames**.

Question 8 (Medium)

At which layer of the OSI Model does **logical addressing (IP Addressing)** and **routing** take place?

- A. Layer 2 - Data Link Layer
- B. Layer 3 - Network Layer
- C. Layer 4 - Transport Layer
- D. Layer 6 - Presentation Layer

Answer: B. Layer 3 - Network Layer

Explanation: The Network Layer is responsible for logical addressing (IP addresses) and path selection (routing).

Question 9 (Medium)

What hardware identifier uniquely identifies a Network Interface Card (NIC) at the Data Link Layer?

- A. IP Address
- B. MAC Address
- C. Port Number
- D. URL

Answer: B. MAC Address

Explanation: The MAC (Media Access Control) address is the hardware address that uniquely identifies a network device / NIC.

Question 10 (Medium)

Which OSI layer is responsible for data encryption, data compression, and syntax conversion?

- A. Application Layer
- B. Presentation Layer
- C. Session Layer
- D. Transport Layer

Answer: B. Presentation Layer

Explanation: Responsibilities of the Presentation Layer include data encryption, data compression, and data conversion.

Question 11 (Hard)

How many total individual physical links are required to create a fully connected **Mesh Topology** for N network nodes?

- A. $N - 1$
- B. N
- C. $\frac{N(N - 1)}{2}$

- D. N^2

Answer: C. $\frac{N(N - 1)}{2}$

Explanation: In a fully connected mesh network, every node has a dedicated point-to-point link to every other node, requiring $\frac{N(N-1)}{2}$ total physical links.

Question 12 (Hard)

In the TCP/IP Reference Model, which OSI layers are combined into the single **TCP/IP Application Layer**?

- A. Layers 1, 2, and 3 (Physical, Data Link, Network)
- B. Layers 3 and 4 (Network, Transport)
- C. Layers 5, 6, and 7 (Session, Presentation, Application)
- D. Layers 4 and 5 (Transport, Session)

Answer: C. Layers 5, 6, and 7 (Session, Presentation, Application)

Explanation: As shown in the OSI vs TCP/IP mapping diagram, the TCP/IP Application layer encompasses the Session, Presentation, and Application layers of the OSI model.

Question 13 (Hard)

What function does **Flow Control** perform at the Transport and Data Link layers?

- A. Encrypts network packets prior to radio transmission
- B. Moderates data transmission speed so a fast sending device does not overwhelm a slower receiving device
- C. Assigns static IP addresses to domain names
- D. Translates physical MAC addresses into IP addresses

Answer: B. Moderates data transmission speed so a fast sending device does not overwhelm a slower receiving device

Explanation: Flow control manages data transmission between devices so that the transmitting device does not send more data than the receiving device can process.

Question 14 (Hard)

Which specific function is handled by the **Session Layer** (Layer 5) to prevent catastrophic loss during long data operations?

- A. Packet Fragmentation
- B. Checkpoint Synchronization
- C. MAC Address Filtering
- D. Voltage Regulation

Answer: B. Checkpoint Synchronization

Explanation: The session layer provides synchronization by inserting checkpoints into the data stream so after a crash, only data transferred after the last checkpoint needs to be repeated.

Question 15 (Hardest)

A company needs to implement a network spanning multiple remote sites over public infrastructure securely, while ensuring that even if one internal link fails, high availability is maintained. Which combination of network classification, architecture, and topology best meets these requirements?

- A. Local Area Network (LAN), Peer-to-Peer, Bus Topology
- B. Virtual Private Network (VPN), Client-Server, Mesh Topology
- C. Metropolitan Area Network (MAN), Workgroup, Ring Topology
- D. Public Switched Network, Peer-to-Peer, Star Topology

Answer: B. Virtual Private Network (VPN), Client-Server, Mesh Topology

Explanation: A VPN uses public networks securely; Client-Server supports centralized data/security management; and Mesh topology provides maximum redundancy and fault tolerance against node/link failures.